

PENILAIAN RISIKO KEAMANAN INFORMASI PADA SISTEM INFORMASI MANAJEMEN RUMAH SAKIT MENGGUNAKAN KERANGKA KERJA ISO/IEC 27005:2022

(Studi Kasus: Rumah Sakit XYZ)

Martin Solehudin Mujib

Program Studi Magister, Fakultas Teknik Informatika, Universitas Langlangbuana

martinsolehudin182@gmail.com

Abstrak— Sistem informasi manajemen rumah sakit (SIMRS) merupakan sistem yang krusial dalam mendukung operasional rumah sakit, mulai dari pencatatan pasien, manajemen data medis, hingga administrasi dan keuangan. Keamanan informasi dalam SIMRS sangat penting karena sistem ini menangani data sensitif dan pribadi pasien, serta informasi operasional rumah sakit yang bersifat kritis. Untuk mengatasi tantangan ini, implementasi kontrol keamanan yang efektif dalam SIMRS menjadi sangat penting. Salah satu metode yang telah terbukti efektif adalah ISO/IEC 27005:2022 yang merupakan standar internasional yang menyediakan panduan untuk manajemen risiko keamanan informasi. Hasil penelitian ini memberikan panduan bagi rumah sakit dalam mengelola risiko keamanan informasi dan juga meningkatkan kesadaran akan pentingnya keamanan informasi di sektor kesehatan..

Kata kunci— SIMRS, ISO/IEC 27005:2022, Keamanan Informasi.

I. PENDAHULUAN

Sistem informasi manajemen rumah sakit (SIMRS) merupakan sistem yang krusial dalam mendukung operasional rumah sakit, mulai dari pencatatan pasien, manajemen data medis, hingga administrasi dan keuangan. Keamanan informasi dalam SIMRS sangat penting karena sistem ini menangani data sensitif dan pribadi pasien, serta informasi operasional rumah sakit yang bersifat kritis. Oleh karena itu, penilaian risiko keamanan informasi menjadi hal yang vital untuk menjaga kerahasiaan, integritas, dan ketersediaan informasi tersebut.

Pentingnya keamanan Informasi dalam SIMRS bertujuan untuk melindungi data dari ancaman seperti akses tidak sah, kehilangan data, dan kerusakan sistem. Risiko keamanan informasi yang tidak dikelola dengan baik dapat menyebabkan berbagai masalah seperti kebocoran data pasien, gangguan operasional, hingga kerugian finansial dan reputasi rumah sakit.

Untuk mengatasi tantangan ini, implementasi kontrol keamanan yang efektif dalam SIMRS menjadi sangat penting. Salah satu metode yang telah terbukti efektif

adalah ISO/IEC 27005:2022 yang merupakan standar internasional yang menyediakan panduan untuk manajemen risiko keamanan informasi. Standar ini mendukung implementasi ISO/IEC 27001 dan memberikan pendekatan sistematis untuk mengidentifikasi, menilai, dan mengelola risiko keamanan informasi. Dengan menggunakan kerangka kerja ini, rumah sakit dapat memastikan bahwa risiko keamanan informasi dikelola dengan efektif dan efisien.

Dengan demikian penilaian risiko keamanan informasi menjadi suatu keharusan untuk keberlangsungan operasional rumah sakit. Melalui penilaian risiko yang komprehensif, rumah sakit dapat mengimplementasikan langkah-langkah mitigasi yang tepat untuk melindungi data dan sistem mereka..

II. METODE

ISO/IEC 27005:2022.

ISO/IEC 27005:2022 merupakan standar internasional yang menyediakan pedoman untuk melakukan proses manajemen risiko keamanan informasi. Data yang digunakan dalam penelitian ini adalah hasil wawancara dengan pihak yang bertanggung jawab dalam pengelolaan sistem informasi.

Tahapan ISO 27005:2022 sebagai berikut :

- Pengumpulan Data

Tahap pengumpulan data melalui wawancara, observasi, studi pustaka dan dokumentasi. Wawancara dan observasi dilakukan kepada pihak yang bertanggung jawab di bidang teknologi informasi.

- Wawancara

Kegiatan wawancara dilakukan dengan melakukan tanya jawab kepada kepala IT RS untuk mengetahui dan mendapatkan wawasan mengenai kerentanan, ancaman potensial, serta tantangan keamanan yang sering mereka hadapi saat ini. Untuk hasil wawancara dapat dilihat pada Gambar 1.

Hari/Tanggal	Tempat	Nama	Jabatan	Hasil
Kamis, 1 Agustus 2024	Ruang IT RS Muhammadiyah Bandung Selatan	Gunawan Aditya	Kepala IT	Rumah sakit ini sebelumnya terkendala dengan penerapan jaringan yang tidak stabil dan kurangnya pemahaman user pengguna aplikasi pada saat penginputan data di aplikasi SIMRS yang mengakibatkan Operasional terganggu dan tidak berjalan dengan baik.

Gambar 1. Hasil Wawancara

• Observasi

Metode observasi dalam penelitian ini dilakukan secara langsung di Rumah Sakit XYZ dengan melihat dan mengumpulkan data yang dibutuhkan. Observasi ini akan memberikan pemahaman tentang bagaimana data diakses, dikelola dan disimpan dalam lingkungan yang sebenarnya. Kegiatan observasi dilakukan pada bulan Agustus tahun 2024. Selama observasi, peneliti secara mendalam memeriksa pengelolaan data karyawan, akses pengguna, tindakan pengamanan, serta respon terhadap potensi ancaman keamanan. Hasil observasi yang dilakukan menjadi landasan penting untuk mengevaluasi keefektifan langkah-langkah pengamanan yang ada dan mengidentifikasi area-area yang memerlukan perbaikan atau peningkatan seperti pada gambar berikut :

Hari/Tanggal	Hasil Temuan	Penjelasan
Senin, 11 Agustus 2023		RS Muhammadiyah Bandung Selatan tidak menggunakan SSL pada SIMRS, yang mengakibatkan risiko keamanan serius. Tanpa adanya enkripsi SSL, data sensitif seperti informasi login dan informasi pribadi dapat dicuri oleh penyerang yang mengintip lalu lintas data. Selain itu, penyerang dapat memanipulasi lalu lintas web untuk menyisipkan perangkat lunak berbahaya atau malware ke perangkat pengguna.

Gambar 2. Hasil Observasi

• Studi Literatur

Studi literatur dalam penyusunan laporan penelitian ini dilakukan dengan cara membaca, mempelajari, dan memahami berbagai jenis sumber informasi seperti buku, e-book, artikel jurnal, dan penelitian-penelitian terdahulu yang relevan dengan permasalahan penelitian. Adapun penelitian terkait yang menjadi referensi dalam penelitian ini. Alasan utama pemilihan ISO 27005:2022 berfokus secara eksklusif pada risiko yang berkaitan dengan keamanan informasi. Ini membuatnya lebih tepat dan relevan untuk organisasi yang ingin melindungi data dan informasi sensitif dari ancaman.

• Penetapan Konteks

Menetapkan konteks penilaian risiko keamanan informasi, meliputi :

- Penetapan pendekatan manajemen risiko serta kriteria kemungkinan (likelihood), kriteria

dampak, nilai/tingkat risiko, dan keberterimaan risiko.

- Pendefinisian ruang lingkup dan batasan manajemen risiko keamanan informasi, yaitu: aplikasi, infrastruktur TI, data.
- Penetapan organisasi dan tanggung jawabnya terhadap pelaksanaan manajemen risiko keamanan informasi.

• Penilaian Risiko

Proses penilaian risiko keamanan informasi pada sistem informasi manajemen rumah sakit dilakukan melalui tiga tahapan yaitu identifikasi risiko, identifikasi ancaman dan kerentanan, analisis risiko, evaluasi risiko.

• Identifikasi Risiko

Identifikasi risiko terdiri dari beberapa proses diantaranya identifikasi aset, identifikasi ancaman dan identifikasi existing control & identifikasi vulnerabilities. Identifikasi aset yang dimiliki oleh RS XYZ dalam menjalankan sistem informasi terdiri dari aset utama berupa:

- Aplikasi SIMRS: Sistem utama yang digunakan untuk mengelola data medis pasien, pendaftaran pasien, rekam medis, pemberian obat, serta transaksi keuangan.
- Server SIMRS: Infrastruktur server yang menyimpan data SIMRS dan mendukung akses ke sistem oleh staf rumah sakit.
- Data Pasien: Informasi sensitif yang mencakup rekam medis pasien, riwayat kesehatan, hasil penunjang medis, dan informasi pribadi lainnya.
- Jaringan Rumah Sakit: Jaringan komputer yang menghubungkan sistem SIMRS dengan berbagai perangkat yang digunakan oleh rumah sakit.

• Identifikasi Ancaman dan Kerentanan

Berikut adalah ancaman dan kerentanan yang diidentifikasi pada aset SIMRS:

- Aplikasi SIMRS RS
- Server SIM RS
- Data Pasien
- Jaringan

• Analisis Risiko

Analisis Risiko (Risk Analysis) Risiko dianalisis berdasarkan dua parameter utama, yaitu:

- Kemungkinan (Likelihood): Kemungkinan suatu ancaman akan terjadi dinilai berdasarkan data historis, frekuensi kejadian, dan lingkungan teknis yang digunakan oleh SIMRS. Kemungkinan diukur dalam skala 1 hingga 5, dengan 1 berarti sangat kecil kemungkinan, dan 5 berarti sangat besar kemungkinan.
- Dampak (Impact): Dampak ancaman diukur berdasarkan konsekuensi yang akan diterima rumah sakit jika ancaman tersebut terjadi.

Dampak diukur dari segi keuangan, kepatuhan hukum, reputasi, dan ketersediaan layanan. Dampak juga dinilai dalam skala 1 hingga 5, dengan 1 berarti dampak kecil, dan 5 berarti dampak sangat besar.

- Evaluasi Risiko

Evaluasi risiko dilakukan untuk menentukan apakah risiko yang teridentifikasi dapat diterima atau harus dikelola lebih lanjut. Risiko dengan nilai tinggi atau sangat tinggi dianggap tidak dapat diterima dan memerlukan tindakan mitigasi segera, sementara risiko dengan nilai menengah masih bisa diterima dengan kontrol terbatas. Evaluasi dilakukan dengan mempertimbangkan dampak risiko terhadap kerahasiaan, integritas, dan ketersediaan informasi serta kepatuhan.

- Evaluasi Risiko

Penanganan Risiko (Risk Treatment) Penanganan risiko dilakukan sesuai dengan strategi yang diatur dalam ISO/IEC 27005:2022, yang mencakup:

- Risk Modification: Mengurangi kemungkinan atau dampak risiko dengan menerapkan kontrol keamanan tambahan, seperti otentikasi dua faktor (2FA), enkripsi, redundansi jaringan, dan pelatihan pengguna.
- Risk Retention: Menerima risiko jika dampaknya rendah dan tidak memerlukan mitigasi lebih lanjut.
- Risk Avoidance: Menghindari aktivitas yang dapat menimbulkan risiko yang tinggi jika risiko tidak bisa dikelola secara efektif.
- Risk Sharing: Mengalihkan sebagian atau seluruh risiko kepada pihak ketiga, seperti vendor, atau menggunakan asuransi.

- Penanganan Risiko

Rancangan kontrol keamanan dilakukan dengan mengacu pada ISO/IEC 27001 dan Annex A, untuk mengurangi risiko yang telah diidentifikasi pada tahap evaluasi risiko. Kontrol ini meliputi langkah-langkah seperti pengaturan akses, enkripsi data, audit sistem secara berkala.

III. HASIL DAN PEMBAHASAN

Data yang di dikumpulkan melalui sesi wawancara yang dilakukan dengan tim IT dan manajemen Rumah Sakit XYZ secara langsung terhadap sistem terkait SIMRS RS XYZ. Sebagai berikut :

Dengan hasil wawancara yang berfokus pada pengumpulan data yang mencakup sasaran keamanan SIMRS, risiko yang menghambat operasional SIMRS, serta kendala yang akan dihadapi RS XYZ.

A. Sasaran Keamanan SIMRS RS XYZ

Dalam keamanan informasi, SIMRS (Sistem Informasi Manajemen Rumah Sakit) harus mengikuti aturan yang ditetapkan oleh undang-undang dan standar keamanan internasional, seperti ISO/IEC 27001. Beberapa regulasi

lokal, seperti Undang-Undang Nomor 11 Tahun 2008 tentang Informasi dan Transaksi Elektronik (ITE) serta peraturan terkait kerahasiaan data kesehatan, juga menjadi acuan. Sasaran keamanan SIMRS ini harus mengacu pada tiga prinsip utama yang diatur oleh standar ISO dan Annex A ISO 27001:

- Kerahasiaan (*Confidentiality*):

Melindungi data pasien dan rekam medis dari akses tidak sah sesuai dengan Annex A.8 dalam ISO 27001, yang mengatur perlindungan terhadap data pribadi dan sensitif. Berdasarkan UU ITE dan Peraturan Menteri Kesehatan No. 269/MENKES/PER/III/2008 tentang Rekam Medis, rumah sakit wajib menjaga kerahasiaan informasi pasien. Data pasien dianggap sebagai informasi sensitif yang harus dilindungi dari akses oleh pihak yang tidak berwenang.

- Integritas (*Integrity*):

Memastikan keakuratan dan kelengkapan data dalam SIMRS sesuai dengan Annex A.9.1.1 dalam ISO 27001, yang mengatur pembatasan akses dan perlindungan data dari modifikasi yang tidak sah.

- Ketersediaan (*Availability*):

Memastikan bahwa SIMRS selalu tersedia untuk diakses oleh staf medis ketika diperlukan, tanpa adanya downtime yang signifikan, sesuai dengan Annex A.11.1 dalam ISO 27001 yang mengatur perlindungan fisik dan lingkungan untuk memastikan ketersediaan sistem.

B. Risiko yang Menghambat Operasional SIMRS

- Risiko Kegagalan Jaringan

Gangguan operasional yang signifikan akibat kegagalan jaringan dapat menyebabkan keterlambatan dalam penanganan pasien, menurunkan kualitas layanan kesehatan.

- Risiko Tidak Ada Enkripsi Data

Penyadapan data pasien selama transmisi dapat menyebabkan pencurian data, yang mengakibatkan tuntutan hukum dan denda sesuai dengan aturan perlindungan data yang berlaku.

- Risiko Human Error

Kesalahan pengguna dalam memasukkan data dapat menyebabkan kesalahan diagnosis atau pengobatan yang berujung pada kerugian bagi pasien dan reputasi rumah sakit.

C. Ruang Lingkup Penggunaan Operasional SIMRS

- Pendaftaran: Pasien melakukan registrasi melalui sistem online atau di meja administrasi.

- Pengelolaan Rekam Medis: Staf medis dapat mengakses dan memperbarui data pasien melalui SIMRS.

- Penanganan Medis: SIMRS memfasilitasi pelayanan pasien, seperti penginputan catatan medis pasien oleh perawat/ dokter.

- Pengelolaan hasil penunjang medis: SIMRS menyediakan penginputan hasil baik itu yang diisi manual maupun bersifat upload
- Pemberian Obat farmasi : SIMRS menyediakan fitur penjualan obat pada pasien yang mana obat tersebut bersumber dari e-resep yang diinputkan oleh dokter.
- Pembayaran: Setelah pelayanan selesai, sistem menghasilkan tagihan yang dibayarkan oleh pasien..

D. Penetapan Konteks

Penerapan kerangka kerja ISO/IEC 27005:2022 dimulai dengan identifikasi konteks untuk memahami lingkungan operasional SIMRS dan ancaman serta kerentanan yang mungkin saja dihadapi oleh Rumah Sakit XYZ.

1. Pendekatan manajemen risiko yang diambil mengikuti standar ISO/IEC 27005:2022.
 2. Ruang Lingkup Penilaian Risiko Ruang lingkup penilaian risiko di RS XYZ mencakup seluruh aset yang berhubungan dengan SIMRS, termasuk SIMRS, Infrastruktur, Data pasien dan keuangan.
- a. Kriteria Kemungkinan adalah kriteria untuk mengukur tingkat kemungkinan terjadinya suatu risiko dibagi menjadi tiga tingkatan yaitu rendah, menengah dan tinggi.

Tabel 1. Kriteria Kemungkinan

Tingkat	Level	Frekuensi Kejadian
Rendah	5	Ancaman Dapat Terjadi Di Atas 1 Tahun
Menengah	3	Ancaman Mungkin Terjadi 3 - 5 Bulan
Tinggi	1	Ancaman Mungkin Terjadi Beberapa Kali Dalam Sebulan

- b. Kriteria dampak risiko dapat diklasifikasikan berdasarkan level dampak atau konsekuensi yang diperlukan oleh setiap organisasi. Kriteria dampak dalam asesmen risiko dan keamanan pada Sistem Informasi Rumah Sakit dibagi menjadi tiga tingkatan kecil, menengah dan besar dan dua dampak yaitu dampak pengguna, dampak kerusakan dan dampak reputasi.

Tabel 2. Kriteria Dampak

Tingkat	Level	Dampak Pengguna	Dampak Kerusakan	Dampak Produktivitas	Dampak Reputasi
Kecil	1	Persentase yang sangat kecil.	Memboreskan informasi sepele.	Ancaman serangan sangat sulit untuk memproduksi.	Terdapat Pemberitaan Negatif Yang Dapat Mempengaruhi Kinerja Dan Kebijakan
Menengah	3	Beberapa pengguna, Non-konfigurasi default	Memboreskan informasi sensitif.	Ancaman serangan dapat direproduksi, tetapi hanya dengan jeda waktu dan situasi tertentu.	Terdapat Pemberitaan Negatif Yang Menurunkan Kepercayaan pengguna
Besar	5	Semua pengguna, konfigurasi default, pelanggan utama.	Penyerang dapat menumbangkan sistem keamanan, mendapatkan otorisasi kepercayaan penuh, berjalan Sebagai administrator	Ancaman serangan dapat direproduksi setiap saat dan tidak memerlukan jeda waktu.	Hilangnya Kepercayaan Pengguna

- c. Kriteria Nilai / Tingkat Risiko Untuk penilaian risiko yang ada pada sistem informasi rumah sakit dilakukan dengan matriks penilaian risiko yaitu sebagai berikut.

Tabel 3. Kriteria Nilai/ Tingkat Risiko

Kemungkinan	Dampak		
	Kecil	Menengah	Besar
Rendah	Rendah	Menengah	Tinggi
Menengah	Menengah	Menengah	Tinggi
Tinggi	Menengah	Tinggi	Tinggi

- d. Kriteria keberterimaan risiko dibagi menjadi tiga sesuai dengan nilai risiko seperti pada table 4.

Tabel 4. Kriteria Keberterimaan Risiko

Nilai Risiko	Kriteria Keberterimaan Risiko	Aksi Kendali
Rendah	Risiko Diabaikan	Tidak Perlu Aksi Kendali, Cukup Di Pantau
Menengah	Risiko Diterima	Dilakukan Pengendalian (Mitigasi) Risiko Dengan Menggunakan Sumber Daya Yang Tersedia
Tinggi	Risiko Diterima	Dilakukan Pengendalian (Mitigasi) Risiko Dengan Menggunakan Sumber Daya Yang Dibutuhkan Terlebih Dahulu

- e. Organisasi pengelola risiko adalah orang bertanggung jawab atas pengelolaan risiko operasional

Tabel 5. Organisasi Pengelola Risiko

Unit	Nama	Jabatan
Pemilik Risiko	Dr. Vinna Taulina, MMR	Direktur Rumah Sakit
Koordinator Risiko	Moh. Jalaluddin, SE	Wakil Direktur Rumah Sakit
Pengelola Risiko	Gunawan Aditya Nugraha, S.Kom	IT Rumah Sakit

E. Identifikasi Risiko

Identifikasi risiko mencakup analisis aset-aset utama. Identifikasi risiko dilakukan untuk memahami bagaimana ancaman tersebut berdampak pada setiap aset yang ada, berikut tabel 1 menunjukkan hasil identifikasi ancaman utama yang dapat dihadapi oleh SIMRS XYZ berdasarkan aset, ancaman, kontrol yang ada, dan kerentanannya:

Tabel 6. Identifikasi Risiko

No	Kode	Aset	Ancaman	Kerentanan	Kontrol Keamanan ISO/IEC 27001
1	T1.1	Aplikasi SIMRS	Akses tidak sah	SQL Injection	Annex A.14.2.5 - Secure System Engineering Principles
2	T1.2	Aplikasi SIMRS	Human error	Cross-Site Scripting (XSS)	Annex A.7.2 - Pelatihan dan Kesadaran Keamanan
3	T1.3	Aplikasi SIMRS	Kegagalan jaringan	Tidak adanya redundansi jaringan	Annex A.13.1.3 - Segregation in networks
4	T2.1	Server SIMRS	Serangan DDoS	Serangan DDoS	Annex A.13.1 - Pengamanan Jaringan
5	T2.2	Server SIMRS	Kesalahan akun pengguna	Broken Authentication	Annex A.9.2 - Manajemen Akses Pengguna
6	T3.1	Perangkat Mobile (Laptop/Ponsel)	Malware	Tidak ada proteksi antivirus	Annex A.12.2 - Proteksi Malware
7	T3.2	Perangkat Mobile (Laptop/Ponsel)	Pencurian perangkat	Perangkat mobile tidak terlindungi	Annex A.11.2 - Keamanan Fisik Peralatan
8	T4.1	Data Pasien	Pencurian data	Data sensitif tidak dienkripsi	Annex A.10.1 - Penggunaan Kriptografi
9	T4.2	Data Pasien	Akses tidak sah	Broken Access Control	Annex A.9.2 - Pembatasan Akses Pengguna
10	T5.1	Jaringan Rumah Sakit	Downtime (kegagalan jaringan)	Jaringan tidak stabil atau lambat	Annex A.13.1.3 - Segregation in networks

Penjelasan Risiko Berdasarkan Aset:

1. Aset: Aplikasi SIMRS

•Ancaman: Akses Tidak Sah (Unauthorized Access)
Penyerang dapat menyisipkan kode SQL berbahaya yang memungkinkan akses atau modifikasi data pasien tanpa otorisasi.

•Ancaman: Human Error

Pengguna dapat memasukkan skrip berbahaya yang dijalankan di browser pengguna lain, memungkinkan pencurian data atau modifikasi data.

•Ancaman: Kegagalan Jaringan

Kontrol Keamanan: Implementasi redundansi jaringan dan rencana kelangsungan bisnis sesuai dengan Annex A.17.2 ISO/IEC 27001 untuk menghindari downtime sistem yang kritis.

2. Aset: Server SIMRS

•Ancaman: Serangan DDoS (Distributed Denial of Service)
Kontrol Keamanan: Implementasi firewall canggih dan proteksi terhadap serangan DDoS, serta pemantauan lalu lintas jaringan sesuai Annex A.13.1 ISO/IEC 27001.

•Ancaman: Kesalahan Akun Pengguna

Sistem tidak memiliki autentikasi yang kuat, seperti otentikasi dua faktor (2FA), sehingga memungkinkan akses yang tidak sah.

3. Aset: Perangkat Mobile (Laptop/Ponsel)

•Ancaman: Malware

Tidak adanya proteksi antivirus atau perangkat lunak keamanan pada perangkat mobile yang digunakan oleh staf untuk mengakses SIMRS.

•Ancaman: Pencurian Perangkat

Perangkat mobile yang digunakan untuk mengakses SIMRS tidak dilengkapi dengan enkripsi atau kebijakan penghapusan jarak jauh (remote wipe), membuatnya rentan jika hilang atau dicuri.

4. Aset: Data Pasien

•Ancaman: Pencurian Data

Data pasien disimpan tanpa enkripsi yang memadai, sehingga rentan terhadap pencurian oleh pihak yang tidak berwenang.

•Ancaman: Akses Tidak Sah

Broken Access Control yang memungkinkan pengguna yang tidak berwenang mendapatkan akses ke data pasien.

5. Aset: Jaringan Rumah Sakit

•Ancaman: Downtime (Kegagalan Jaringan)

Jaringan tidak stabil atau lambat dapat mengakibatkan kegagalan dalam mengakses SIMRS, yang dapat berdampak negatif pada pelayanan medis.

F. Analisis Risiko

Berdasarkan hasil identifikasi ancaman dan kerentanan pada aset Sistem Informasi Manajemen Rumah Sakit (SIMRS) RS XYZ, dilakukan analisis risiko untuk menilai seberapa besar ancaman tersebut berdampak pada aset kritis rumah sakit. Risiko dianalisis berdasarkan dua parameter utama:

• Kemungkinan (Likelihood): Menilai seberapa besar kemungkinan suatu ancaman akan terjadi terhadap aset. Kemungkinan ini didasarkan pada data historis, tren ancaman, dan analisis lingkungan teknologi yang digunakan.

• Dampak (Impact): Mengukur seberapa besar kerugian atau konsekuensi yang akan diterima oleh rumah sakit jika ancaman tersebut terjadi. Dampak tidak hanya terbatas pada aspek finansial, tetapi juga meliputi aspek hukum, reputasi, serta ketersediaan layanan kesehatan kepada pasien.

Nilai Risiko dan Klasifikasinya

Nilai risiko dihitung dengan menggunakan rumus berikut:

Nilai Risiko = Kemungkinan × Dampak

Nilai risiko kemudian diklasifikasikan ke dalam empat kategori:

• Rendah (1-5): Risiko yang bisa diterima tanpa tindakan mitigasi langsung.

• Menengah (6-10): Risiko yang memerlukan perhatian dan pengendalian lebih lanjut.

• Tinggi (11-20): Risiko yang memerlukan tindakan mitigasi segera untuk mencegah dampak lebih besar.

• Sangat Tinggi (21-25): Risiko yang sangat kritis dan tidak bisa diterima, memerlukan langkah mitigasi segera.

Tabel 7. Analisa Risiko

No	Aset	Ancaman	Kemungkinan	Dampak	Nilai Risiko	Level Risiko
1	Aplikasi SIMRS	Akses tidak sah	Tinggi	Tinggi	25	Sangat Tinggi
2	Aplikasi SIMRS	Human error	Menengah	Tinggi	15	Tinggi
3	Aplikasi SIMRS	Kegagalan jaringan	Tinggi	Menengah	20	Tinggi
4	Server SIMRS	Serangan DDoS	Tinggi	Tinggi	25	Sangat Tinggi
5	Server SIMRS	Kesalahan akun pengguna	Menengah	Tinggi	12	Menengah
6	Perangkat Mobile (Laptop/Ponsel)	Malware	Menengah	Menengah	9	Menengah
7	Perangkat Mobile (Laptop/Ponsel)	Pencurian perangkat	Tinggi	Tinggi	20	Tinggi
8	Data Pasien	Pencurian data	Sangat Tinggi	Sangat Tinggi	25	Sangat Tinggi
9	Data Pasien	Akses tidak sah	Tinggi	Tinggi	25	Sangat Tinggi
10	Jaringan Rumah Sakit	Downtime (kegagalan jaringan)	Menengah	Tinggi	16	Tinggi

Dampak dari setiap risiko ditentukan berdasarkan skenario terburuk jika ancaman tersebut benar-benar terjadi. Berikut adalah beberapa dampak yang dapat terjadi pada Rumah Sakit XYZ, dilihat dari berbagai perspektif, termasuk aspek hukum dan standar ISO:

1. Akses Tidak Sah pada Aplikasi SIMRS:

- Dampak: Jika terjadi akses tidak sah, hal ini bisa mengakibatkan pencurian atau manipulasi data pasien, yang melanggar Peraturan Menteri Kesehatan No. 82 Tahun 2013 tentang SIMRS dan Peraturan Pemerintah No. 71 Tahun 2019 tentang Perlindungan Data Pribadi. Rumah sakit bisa menghadapi tuntutan hukum, denda, dan kehilangan kepercayaan dari pasien serta masyarakat.
- Standar ISO 27001: Ini merupakan pelanggaran besar terhadap prinsip kerahasiaan dan integritas data, yang menuntut penerapan kontrol akses yang lebih ketat sesuai Annex A.9 - Access Control.

2. Human Error:

- Dampak: Kesalahan manusia, seperti kelalaian dalam input data atau kesalahan konfigurasi sistem, dapat menyebabkan gangguan besar pada operasional rumah sakit. Selain itu, hal ini dapat merusak keakuratan data medis, yang pada akhirnya berisiko terhadap keselamatan pasien.
- Standar ISO 27001: Annex A.7 - Human Resource Security menekankan pentingnya pelatihan dan kesadaran keamanan informasi untuk mengurangi risiko kesalahan manusia.

3. Serangan DDoS pada Server SIMRS:

- Dampak: Serangan Distributed Denial of Service (DDoS) dapat menghentikan layanan SIMRS, menyebabkan downtime yang berkepanjangan. Hal ini akan mempengaruhi kelancaran operasional rumah sakit dan berpotensi menunda tindakan medis yang krusial. Jika server terpengaruh, rumah sakit dapat menghadapi pelanggaran peraturan terkait perlindungan data pasien.

- Standar ISO 27001: Annex A.13.1 - Network Controls mengharuskan penerapan kontrol jaringan yang kuat untuk melindungi server dari serangan DDoS.

4. Pencurian Data Pasien:

- Dampak: Jika data pasien dicuri atau diakses tanpa izin, rumah sakit akan menghadapi risiko hukum yang signifikan, karena ini melanggar aturan Peraturan Menteri Kesehatan No. 269/MENKES/PER/III/2008 tentang Rekam Medis. Dampak reputasi juga sangat serius, karena kepercayaan pasien pada keamanan data mereka akan menurun drastis.

- Standar ISO 27001: Annex A.8.2 - Protection of Sensitive Data menekankan pentingnya enkripsi dan kontrol akses yang kuat untuk melindungi data pasien.

5. Downtime pada Jaringan Rumah Sakit:

- Dampak: Downtime atau kegagalan jaringan dapat menghentikan akses ke SIMRS, mengganggu operasional rumah sakit secara keseluruhan, serta mempengaruhi ketersediaan layanan kesehatan bagi pasien. Keterlambatan dalam pengobatan akibat downtime bisa mengakibatkan kerugian reputasi dan finansial.

G. Evaluasi Risiko

Evaluasi risiko dilakukan untuk menentukan apakah risiko yang teridentifikasi dapat diterima atau harus ditangani dengan kontrol tambahan. Evaluasi ini mempertimbangkan seberapa besar dampak dan kemungkinan terjadinya risiko, serta seberapa kritis dampaknya terhadap operasional SIMRS dan data sensitif di Rumah Sakit XYZ.

Risiko dengan nilai tinggi atau sangat tinggi memerlukan tindakan segera untuk mitigasi atau pengurangan risiko, sedangkan risiko dengan nilai menengah masih dapat diterima dengan tindakan pengendalian yang memadai. Risiko dengan nilai rendah dapat dipantau tanpa membutuhkan tindakan mitigasi yang signifikan.

Berikut ini adalah tabel evaluasi risiko yang telah diidentifikasi:

Tabel 8. Evaluasi Risiko

Kode	Aset	Level Risiko	Keberterimaan Risiko	Aksi Kendali
T1.1	Aplikasi SIMRS	Sangat Tinggi	Risiko Tidak Diterima	Implementasi otentikasi dua faktor (2FA) dan enkripsi SSL untuk proteksi data
T2.1	Server SIMRS	Sangat Tinggi	Risiko Tidak Diterima	Proteksi DDoS, firewall tingkat lanjut, dan pemantauan real-time
T4.1	Data Pasien	Sangat Tinggi	Risiko Tidak Diterima	Enkripsi SSL, audit akses rutin, serta enkripsi saat penyimpanan dan transmisi
T4.2	Data Pasien	Sangat Tinggi	Risiko Tidak Diterima	Penerapan kebijakan otentikasi ketat, validasi akses pengguna
T1.2	Aplikasi SIMRS	Tinggi	Risiko Diterima	Peningkatan pengawasan dan pelatihan pengguna terkait keamanan dan privasi data
T1.3	Aplikasi SIMRS	Tinggi	Risiko Diterima	Implementasi redundansi jaringan untuk menghindari downtime SIMRS
T3.2	Perangkat Mobile (Laptop/Ponsel)	Tinggi	Risiko Diterima	Pengawasan lebih ketat, implementasi kontrol akses untuk proteksi fisik
T3.1	Jaringan Rumah Sakit	Tinggi	Risiko Diterima	Peningkatan redundansi jaringan, monitoring kinerja jaringan secara real-time
T2.2	Server SIMRS	Menengah	Risiko Diterima	Implementasi otentikasi dua faktor (2FA) dan audit akses rutin
T3.1	Perangkat Mobile (Laptop/Ponsel)	Menengah	Risiko Diterima	Instalasi antivirus, penerapan mobile device management (MDM)

Dari evaluasi di atas, risiko dengan nilai sangat tinggi tidak dapat diterima dan memerlukan langkah mitigasi segera melalui kontrol keamanan yang lebih ketat, seperti otentikasi dua faktor (2FA), enkripsi SSL, dan proteksi DDoS. Risiko dengan nilai tinggi diterima namun tetap memerlukan pengendalian seperti redundansi jaringan dan pelatihan pengguna. Risiko menengah dapat diterima dengan tindakan pengendalian yang lebih ringan seperti pemasangan antivirus atau audit rutin.

H. Rencana Penganan Risiko

Langkah penanganan risiko dilakukan sesuai dengan tingkat risiko yang telah dianalisis berdasarkan ISO/IEC 27005. Rencana penanganan risiko ini bertujuan untuk mengurangi risiko melalui kontrol keamanan yang tepat, penerimaan risiko jika dampaknya rendah, atau penghindaran aktivitas yang berisiko tinggi. Strategi penanganan risiko meliputi modifikasi risiko, retensi risiko, penghindaran risiko, dan berbagi risiko.

- Risk Modification (Modifikasi Risiko): Mengurangi kemungkinan atau dampak ancaman dengan menerapkan kontrol keamanan yang lebih baik.
- Risk Retention (Retensi Risiko): Menerima risiko jika dampaknya rendah dan tindakan mitigasi tidak diperlukan.
- Risk Avoidance (Menghindari Risiko): Menghindari aktivitas yang berisiko jika risiko dinilai terlalu tinggi.
- Risk Sharing (Berbagi Risiko): Mengalihkan sebagian atau seluruh risiko kepada pihak ketiga, seperti asuransi atau perjanjian dengan vendor.

Tabel 9. Rencana Penanganan Risiko

No	Aset	Level Risiko	Rencana Penanganan Risiko	Strategi Penanganan (ISO 27005)
1	Aplikasi SIMRS	Sangat Tinggi	Implementasi otentikasi dua faktor (2FA) dan enkripsi SSL	Risk Modification: Mengurangi risiko melalui kontrol teknis seperti 2FA dan enkripsi
2	Aplikasi SIMRS	Tinggi	Peningkatan pengawasan pengguna dan pelatihan keamanan	Risk Modification: Mengurangi risiko melalui peningkatan prosedur operasional dan pelatihan pengguna
3	Aplikasi SIMRS	Tinggi	Menerapkan redundansi jaringan untuk mencegah downtime	Risk Modification: Mengurangi risiko dengan menambah infrastruktur redundansi jaringan
4	Server SIMRS	Sangat Tinggi	Proteksi DDoS, firewall tingkat lanjut, enkripsi data	Risk Modification: Mengurangi risiko dengan menerapkan perlindungan teknis lanjutan seperti firewall dan DDoS protection
5	Server SIMRS	Menengah	Otentikasi dua faktor (2FA) dan audit rutin	Risk Modification: Mengurangi risiko dengan kontrol teknis dan audit keamanan secara berkala
6	Perangkat Mobile (Laptop/Ponsel)	Menengah	Instalasi antivirus, peningkatan pengawasan perangkat	Risk Modification: Mengurangi risiko melalui instalasi antivirus dan kebijakan pengelolaan perangkat
7	Perangkat Mobile (Laptop/Ponsel)	Tinggi	Implementasi kontrol keamanan fisik dan pelacakan perangkat	Risk Sharing: Berbagi risiko dengan vendor atau asuransi untuk perlindungan perangkat yang hilang atau dicuri
8	Data Pasien	Sangat Tinggi	Enkripsi SSL, audit akses rutin, backup harian	Risk Modification: Mengurangi risiko dengan meningkatkan kontrol teknis seperti enkripsi dan audit akses
9	Data Pasien	Sangat Tinggi	Penerapan kebijakan kata sandi kuat dan enkripsi penuh	Risk Modification: Mengurangi risiko melalui penerapan kebijakan keamanan yang ketat dan enkripsi data penuh
10	Jaringan Rumah Sakit	Tinggi	Penerapan failover untuk jaringan dan stabilitas koneksi	Risk Modification: Mengurangi risiko dengan redundansi dan failover untuk jaringan tidak stabil

I. Mitigasi Risiko

Mitigasi risiko dilakukan berdasarkan hasil evaluasi yang menunjukkan bahwa beberapa risiko memiliki level dan dampak sangat tinggi atau tinggi. Risiko-risiko ini memerlukan tindakan mitigasi segera karena dapat menyebabkan gangguan signifikan terhadap operasional SIMRS dan integritas data.

Tabel 9. Rencana Penanganan Risiko

Kode Risiko	Kriteria Penanganan Risiko	Dampak	Opsi Penanganan Risiko
T1.1	Menghilangkan sumber risiko: Akses tidak sah	Pencurian atau manipulasi data pasien, pelanggaran hukum, kehilangan kepercayaan pasien	Implementasi otentikasi dua faktor (2FA) dan enkripsi SSL, audit akses berkala
T4.1	Menghilangkan sumber risiko: Pencurian data	Kebocoran data pasien yang sangat sensitif, kerugian reputasi dan hukum	Enkripsi data saat disimpan dan ditransmisikan, audit akses rutin, backup harian
T4.2	Menghilangkan sumber risiko: Akses tidak sah	Kebocoran data yang berbahaya, kerugian reputasi, dan potensi pelanggaran hukum	Kebijakan otentikasi ketat dengan 2FA dan RBAC, enkripsi data penuh
T2.1	Menghilangkan sumber risiko: Serangan DDoS	Gangguan layanan medis yang serius, operasional SIMRS terganggu	Proteksi DDoS, firewall tingkat lanjut, pemantauan real-time
T1.2	Mengurangi dampak dari Human error	Kesalahan pengguna dapat mengakibatkan kerusakan data atau pelanggaran keamanan	Pelatihan keamanan untuk pengguna, peningkatan pengawasan
T1.3	Mengurangi dampak dari kegagalan jaringan	Downtime SIMRS mengganggu layanan rumah sakit dan ketersediaan data	Redundansi jaringan untuk menghindari downtime
T5.1	Mengurangi dampak dari downtime jaringan	Gangguan dalam pelayanan rumah sakit dan akses SIMRS terganggu	Redundansi dan failover untuk jaringan
T3.2	Menghilangkan sumber risiko: Pencurian perangkat	Data pada perangkat mobile yang hilang dapat diakses pihak yang tidak berwenang	Kontrol akses fisik dan pelacakan perangkat, proteksi perangkat

Risiko dengan Level dan Dampak Sangat Tinggi

1. T1.1 - Aplikasi SIMRS: Akses Tidak Sah

- Dampak: Akses tidak sah dapat menyebabkan pencurian atau manipulasi data pasien, yang dapat melanggar hukum dan menghilangkan kepercayaan pasien terhadap sistem rumah sakit.
- Opsi Penanganan:

O Otentikasi Dua Faktor (2FA): Penerapan 2FA untuk semua pengguna SIMRS akan memastikan bahwa hanya pengguna yang berwenang yang dapat mengakses sistem.

O Enkripsi SSL: Semua data yang dikirimkan melalui jaringan harus dienkripsi dengan SSL untuk melindungi data pasien selama transmisi.

O Audit Akses Berkala: Audit rutin terhadap akses pengguna akan dilakukan untuk mendeteksi aktivitas mencurigakan dan akses tidak sah.

2. T4.1 - Data Pasien: Pencurian Data

- Dampak: Kebocoran data pasien sangat sensitif dan dapat menyebabkan kerugian hukum serta merusak reputasi rumah sakit.

- Opsi Penanganan:

O Enkripsi Data Pasien: Data pasien harus dienkripsi saat disimpan di server (encryption at rest) dan saat dikirim melalui jaringan (encryption in transit).

O Audit Akses Rutin: Melakukan audit akses pengguna terhadap data pasien secara rutin untuk mendeteksi dan mencegah akses tidak sah.

O Backup Harian: Backup data harian harus dilakukan untuk memastikan bahwa data dapat dipulihkan jika terjadi pencurian atau kerusakan.

3. T4.2 - Data Pasien: Akses Tidak Sah

- Dampak: Akses tidak sah terhadap data pasien dapat menyebabkan pelanggaran hukum serius serta kerugian reputasi yang signifikan.

- Opsi Penanganan:

O Kebijakan Otentikasi Ketat: Pengguna yang dapat mengakses data pasien harus mematuhi kebijakan otentikasi ketat, termasuk penggunaan kata sandi kuat dan 2FA.

O Role-Based Access Control (RBAC): Akses ke data pasien harus dibatasi sesuai peran pengguna dalam organisasi, sehingga hanya yang memerlukan akses yang dapat melihat data.

O Enkripsi Data Penuh: Semua data pasien harus dienkripsi penuh menggunakan algoritma yang kuat seperti AES-256 untuk melindungi privasi pasien.

4. T2.1 - Server SIMRS: Serangan DDoS

- Dampak: Serangan Distributed Denial of Service (DDoS) dapat menghentikan operasional SIMRS dan mengganggu layanan medis.

- Opsi Penanganan:

O Proteksi DDoS: Menggunakan solusi proteksi DDoS yang dapat mengidentifikasi dan memblokir serangan DDoS sebelum memengaruhi server.

O Firewall Tingkat Lanjut: Penerapan firewall tingkat lanjut untuk memblokir lalu lintas mencurigakan yang berasal dari sumber yang tidak dikenal.

O Pemantauan Real-Time: Sistem harus dipantau secara real-time untuk mendeteksi pola lalu lintas yang tidak wajar, dan tindakan harus diambil segera jika ditemukan serangan.

Risiko dengan Level dan Dampak Tinggi

1. T1.2 - Aplikasi SIMRS: Human Error

- Dampak: Kesalahan manusia, seperti kesalahan input atau konfigurasi, dapat menyebabkan kerusakan data atau pelanggaran keamanan.

- Opsi Penanganan:

O Pelatihan Keamanan: Pelatihan rutin bagi pengguna SIMRS untuk meningkatkan kesadaran terhadap ancaman keamanan dan cara menangani aplikasi dengan aman.

O Peningkatan Pengawasan: Pengawasan ekstra dilakukan untuk mencegah kesalahan yang dapat berdampak pada integritas data.

2. T1.3 - Aplikasi SIMRS: Kegagalan Jaringan

- Dampak: Kegagalan jaringan dapat menyebabkan downtime SIMRS, yang berdampak pada ketersediaan data dan layanan medis.

- Opsi Penanganan:

O Redundansi Jaringan: Penerapan jalur redundansi jaringan untuk memastikan ketersediaan jaringan bahkan saat terjadi kegagalan pada jalur utama.

3. T5.1 - Jaringan Rumah Sakit: Downtime (Kegagalan Jaringan)

- Dampak: Downtime pada jaringan rumah sakit dapat menghambat pelayanan medis, yang dapat mengganggu akses SIMRS dan mengakibatkan hilangnya produktivitas.

- Opsi Penanganan:

O Redundansi dan Failover: Penerapan mekanisme failover pada jaringan untuk menjaga ketersediaan jaringan meskipun ada kegagalan jaringan utama.

4. T3.2 - Perangkat Mobile: Pencurian Perangkat

- Dampak: Jika perangkat mobile yang digunakan untuk mengakses SIMRS hilang atau dicuri, data sensitif yang tersimpan di perangkat dapat jatuh ke tangan yang salah.

- Opsi Penanganan:

O Kontrol Akses Fisik: Menjaga perangkat dengan pengamanan fisik yang kuat, seperti penguncian perangkat saat tidak digunakan.

O Pelacakan Perangkat: Menggunakan teknologi pelacakan perangkat untuk menemukan perangkat yang hilang dan menghapus data jarak jauh jika diperlukan

J. Rancangan Kontrol Keamanan

Tahapan dalam penilaian risiko yang sudah dilakukan terhadap Sistem Informasi Manajemen Rumah Sakit (SIMRS) di RS XYZ memberikan gambaran mengenai risiko-risiko yang dihadapi. Kontrol keamanan yang diterapkan harus sesuai dengan hasil evaluasi dan mengikuti panduan standar keamanan informasi yang relevan, seperti ISO/IEC 27001. Pada bagian ini, rancangan kontrol keamanan disusun berdasarkan hasil evaluasi risiko, dimana setiap kontrol keamanan yang diterapkan bertujuan untuk memitigasi risiko yang telah teridentifikasi.

Berikut adalah penjelasan tahapan dan rancangan kontrol keamanan untuk setiap aset utama yang telah diidentifikasi:

Kode Risiko	Nama Aset	Kode Kerentanan	Kode Ancaman	Nilai Risiko	Kontrol Keamanan	Deskripsi Kontrol Keamanan
R1	Aplikasi SIMRS	V1.1	T1.1 Akses tidak sah	Sangat Tinggi	A.9.4.1 Information access restriction	Pembatasan akses informasi hanya untuk pengguna yang berwenang dengan kebijakan otorisasi yang ketat.
R2	Aplikasi SIMRS	V1.2	T1.2 Human error	Tinggi	A.7.2.2 Information security awareness, education, and training	Pelatihan dan edukasi keamanan informasi untuk meningkatkan kesadaran pengguna terhadap risiko dan prosedur aman.
R3	Aplikasi SIMRS	V1.3	T1.3 Kegagalan jaringan atau lambat	Tinggi	A.12.1.3 Capacity management	Pengelolaan kapasitas jaringan untuk memastikan ketersediaan dan performa jaringan yang optimal.
R4	Server SIMRS	V2.1	T2.1 Serangan DDoS	Sangat Tinggi	A.13.1.1 Network controls	Menerapkan kontrol jaringan yang kuat seperti firewall dan DDoS protection untuk mencegah serangan terhadap server.
R5	Server SIMRS	V2.2	T2.2 Kesalahan akun pengguna	Menengah	A.9.2.4 Management of secret authentication information	Mengelola informasi autentikasi dengan aman, termasuk penyimpanan dan distribusi kata sandi dan kunci enkripsi.
R6	Perangkat Mobile	V3.1	T3.1 Malware	Menengah	A.12.2.1 Protection from malware	Proteksi perangkat mobile dari malware dengan penerapan antivirus dan kebijakan keamanan perangkat.
R7	Perangkat Mobile	V3.2	T3.2 Pencurian perangkat	Tinggi	A.11.2.6 Security of equipment and assets off-premises	Mengamankan perangkat yang digunakan di luar lokasi rumah sakit dengan kebijakan pelacakan dan enkripsi perangkat.
R8	Data Pasien	V4.1	T4.1 Pencurian data	Sangat Tinggi	A.8.2.3 Encryption and anonymization of sensitive data	Mengenkripsi dan menganonimkan data pasien untuk mencegah akses oleh pihak yang tidak berwenang.

Tabel 9. Rancangan Kontrol Keamanan

R9	Data Pasien	V4.2	T4.2 Akses tidak sah	Sangat Tinggi	A.8.2.1 Ownership of sensitive data and auditing	Menetapkan kepemilikan data yang jelas serta melakukan audit akses secara berkala untuk mendeteksi pelanggaran.
R10	Jaringan Rumah Sakit	V5.2	T5.2 Downtime jaringan	Tinggi	A.12.4.1 Redundancy and failover controls	Menerapkan kontrol redundansi jaringan dan mekanisme failover untuk memastikan ketersediaan jaringan.

Deskripsi Kontrol Keamanan

• A.9.4.1 Information Access Restriction (Pembatasan Akses Informasi):

Tujuan: Membatasi akses informasi hanya kepada pihak yang berwenang. Penerapan kontrol akses yang ketat melalui kebijakan otorisasi yang memastikan hanya pengguna yang memiliki hak akses tertentu dapat mengakses data sensitif di SIMRS.

• A.7.2.2 Information Security Awareness, Education, and Training (Pelatihan dan Kesadaran Keamanan Informasi):

Tujuan: Mengurangi risiko human error dengan memberikan pelatihan kepada pengguna terkait keamanan informasi. Pengguna diberi pelatihan reguler terkait keamanan informasi, prosedur penggunaan yang aman, serta kesadaran akan risiko yang bisa timbul akibat kelalaian atau kesalahan manusia.

• A.12.1.3 Capacity Management (Manajemen Kapasitas):

Tujuan: Mengatasi masalah kegagalan atau lambatnya performa jaringan SIMRS. Deskripsi: Pengelolaan kapasitas jaringan secara proaktif untuk memastikan bahwa infrastruktur jaringan rumah sakit memiliki kapasitas yang cukup untuk menangani beban operasional.

• A.13.1.1 Network Controls (Kontrol Jaringan):

Tujuan: Mencegah serangan pada server SIMRS, terutama serangan DDoS. Penerapan kontrol keamanan jaringan yang kuat, termasuk penggunaan firewall, sistem deteksi intrusi (IDS), dan perlindungan terhadap serangan Distributed Denial of Service (DDoS).

• A.9.2.4 Management of Secret Authentication Information (Pengelolaan Informasi Autentikasi Rahasia):

Tujuan: Melindungi akun pengguna dari kesalahan yang dapat menyebabkan akses tidak sah. Menyimpan dan mengelola kata sandi serta informasi autentikasi lainnya dengan aman, termasuk penggunaan enkripsi untuk penyimpanan kata sandi.

• A.12.2.1 Protection from Malware (Proteksi dari Malware):

Tujuan: Melindungi perangkat mobile yang digunakan dalam operasional SIMRS dari malware. Instalasi antivirus yang selalu diperbarui dan menjalankan kebijakan proteksi perangkat untuk meminimalkan risiko terinfeksi malware.

• A.11.2.6 Security of Equipment and Assets Off-Premises (Keamanan Perangkat di Luar Lokasi):

Tujuan: Melindungi perangkat yang digunakan di luar lokasi fisik rumah sakit dari pencurian. Mengimplementasikan kebijakan keamanan untuk perangkat yang digunakan di luar rumah sakit, termasuk pelacakan perangkat dan enkripsi data di dalam perangkat.

• A.8.2.3 Encryption and Anonymization of Sensitive Data (Enkripsi dan Anonimisasi Data Sensitif):

Tujuan: Melindungi privasi data pasien dengan mengenkripsi dan menganonimkan data sensitif.

Data pasien dienkripsi selama penyimpanan dan transmisi, serta anonimisasi dilakukan untuk melindungi privasi dalam kondisi tertentu.

• A.8.2.1 Ownership of Sensitive Data and Auditing (Kepemilikan Data Sensitif dan Audit):

Tujuan: Menjamin kepemilikan dan perlindungan data sensitif dengan melakukan audit rutin. Kepemilikan data sensitif dijelaskan dengan jelas, serta akses ke data ini diaudit secara berkala untuk mengidentifikasi dan mengatasi potensi pelanggaran keamanan.

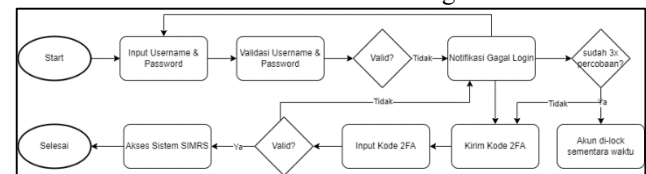
• A.12.4.1 Redundancy and Failover Controls (Redundansi dan Kontrol Failover):

Tujuan: Menjaga ketersediaan jaringan agar SIMRS selalu dapat diakses tanpa gangguan. Menerapkan mekanisme failover dan redundansi pada jaringan rumah sakit, sehingga jika terjadi kegagalan pada satu bagian jaringan, jalur alternatif tersedia untuk menjaga operasional.

Rancangan Model Keamanan

1. Otentikasi Dua Faktor (2FA)

• Kontrol Keamanan: A.9.4.2 Secure Log-On Procedures



Gambar 3. Rancangan Model Keamanan Otentikasi Dua Faktor (2FA)

Penerapan Model:

1. Tahap Login: Otentikasi dua faktor (2FA) diterapkan pada tahap login pengguna. Pengguna akan memasukkan username dan password terlebih dahulu. Setelah itu, sistem akan mengirimkan kode verifikasi ke perangkat pengguna melalui SMS atau aplikasi autentikasi (Google Authenticator/OTP).

2. Validasi Otentikasi: Pengguna harus memasukkan kode yang diterima untuk menyelesaikan proses login. Jika gagal memasukkan kode yang benar dalam tiga kali percobaan, akun akan di-lock untuk sementara waktu.

3. Skenario Penggunaan:

• Login Awal: Setiap kali pengguna login ke SIMRS, 2FA akan diterapkan untuk meningkatkan keamanan akses.

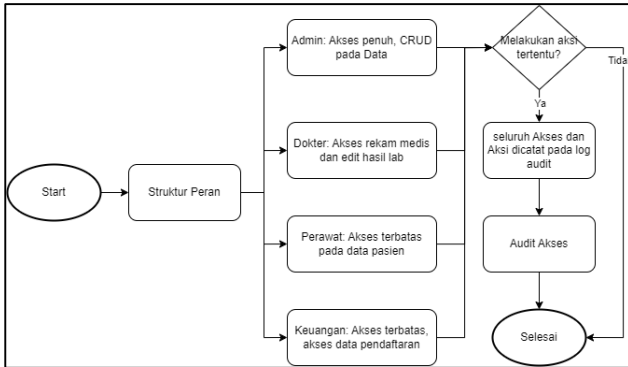
• Aksi Berisiko: Otentikasi 2FA juga diterapkan pada aksi kritis seperti penghapusan data pasien, perubahan informasi akun pengguna, atau transaksi keuangan. Setiap kali pengguna melakukan tindakan ini, mereka akan diminta untuk mengulang otentikasi dengan kode 2FA.

• Keamanan Tambahan: Jika pengguna mengakses dari perangkat baru atau lokasi geografis yang tidak dikenal,

2FA akan otomatis diaktifkan kembali meskipun pengguna sudah pernah melakukan login di perangkat lain

2. Pembatasan Akses Berdasarkan Peran (Role-Based Access Control - RBAC)

- Kontrol Keamanan: A.9.4.1 Information Access Restriction



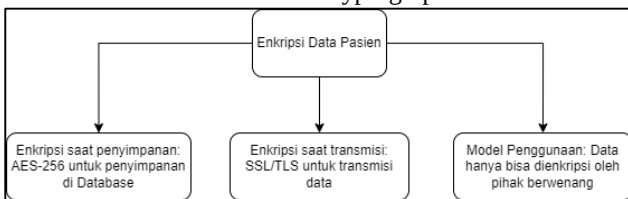
Gambar 4. Rancangan Model 2. Pembatasan Akses Berdasarkan Peran (Role-Based Access Control - RBAC)

Penerapan Model:

- Struktur Peran: Setiap pengguna SIMRS dikelompokkan berdasarkan peran mereka, seperti admin, dokter, perawat, dan bagian keuangan. Setiap peran memiliki akses yang terbatas pada modul tertentu di sistem, berdasarkan kebutuhan fungsionalnya.
- Pembatasan Akses: Pengguna hanya dapat mengakses data yang relevan dengan peran mereka. Misalnya, hanya dokter yang dapat melihat data rekam medis lengkap pasien, sedangkan staf administrasi hanya dapat mengakses data pendaftaran.
- Aksi Tertentu: Misalnya, tindakan seperti penghapusan data pasien atau perubahan hasil laboratorium hanya dapat dilakukan oleh admin atau dokter yang berwenang, dan tidak bisa diakses oleh staf dengan peran lain.
- Audit Akses: Semua akses ke data sensitif seperti rekam medis pasien akan dicatat dalam log audit, yang memungkinkan admin untuk melihat siapa yang mengakses data, kapan, dan untuk tujuan apa.

3. Enkripsi Data Pasien

- Kontrol Keamanan: A.10.1 Cryptographic Controls



Gambar 5. Rancangan Model 3. Enkripsi Data Pasien

Penerapan Model:

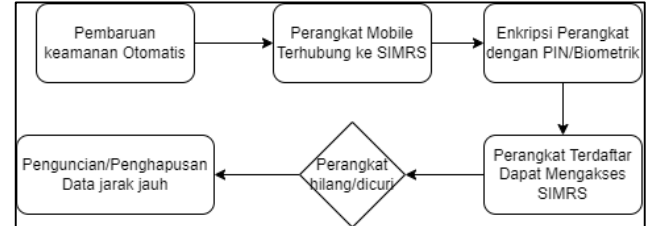
- Enkripsi Saat Penyimpanan: Data sensitif pasien, seperti hasil medis dan informasi pribadi, akan dienkripsi dengan algoritma AES-256 selama penyimpanan di database SIMRS. Ini memastikan bahwa jika terjadi pelanggaran keamanan atau akses tidak sah ke server, data yang dicuri tetap dalam bentuk terenkripsi.
- Enkripsi Saat Transmisi: Setiap kali data pasien ditransmisikan antar-sistem (misalnya antara aplikasi

SIMRS dan perangkat mobile), data akan dienkripsi menggunakan SSL/TLS untuk mencegah serangan man-in-the-middle.

- Model Penggunaan: Sistem akan memastikan bahwa setiap data yang diakses atau dikirimkan melalui jaringan, baik dari perangkat mobile atau desktop, selalu dalam bentuk terenkripsi, dan hanya bisa didekripsi oleh pihak yang berwenang.

4. Pengelolaan Keamanan Perangkat Mobile (Mobile Device Management - MDM)

- Kontrol Keamanan: A.6.2.1 Mobile Device Security



Gambar 6. Rancangan Model Pengelolaan Keamanan Perangkat Mobile (Mobile Device Management - MDM)

Penerapan Model:

- Registrasi Perangkat: Setiap perangkat mobile yang digunakan oleh staf medis untuk mengakses SIMRS akan diregistrasi ke dalam sistem MDM. Hanya perangkat yang terdaftar yang dapat mengakses data SIMRS.
- Penguncian dan Penghapusan Jarak Jauh: Jika perangkat mobile yang digunakan untuk mengakses SIMRS hilang atau dicuri, sistem dapat melakukan penguncian atau penghapusan data jarak jauh (remote wipe) untuk memastikan data sensitif pasien tidak jatuh ke tangan yang salah.
- Enkripsi Perangkat: Semua perangkat mobile yang terhubung ke SIMRS harus dienkripsi dan dilengkapi dengan proteksi PIN atau biometrik (misalnya, sidik jari atau pengenalan wajah) sebagai syarat untuk membuka akses aplikasi SIMRS.
- Pembaruan Keamanan Otomatis: Perangkat mobile akan dipaksa untuk menerima pembaruan keamanan secara otomatis untuk melindungi dari malware atau kerentanan baru yang ditemukan.

5. Perlindungan dari Serangan DDoS

- Kontrol Keamanan: A.13.1.1 Network Controls

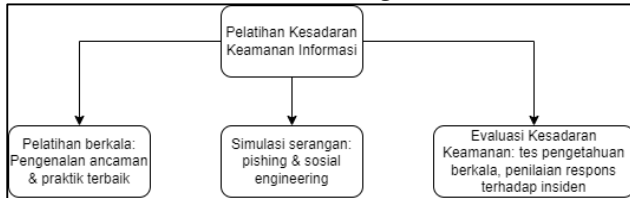
Penerapan Model:

- Firewall dan IDS/IPS: Server SIMRS dilindungi dengan firewall canggih serta sistem deteksi dan pencegahan intrusi (IDS/IPS). Firewall akan memblokir lalu lintas dari sumber yang tidak dipercaya, dan IDS/IPS akan memantau aktivitas jaringan untuk mendeteksi dan mencegah serangan Distributed Denial of Service (DDoS).
- Model Failover: Jika terjadi serangan DDoS yang mencoba membanjiri jaringan, sistem akan otomatis beralih ke server cadangan (failover) untuk memastikan bahwa layanan SIMRS tetap tersedia bagi pengguna internal rumah sakit.
- Pemantauan Real-Time: Sistem akan memonitor lalu lintas jaringan secara real-time dan mengidentifikasi pola lalu lintas yang mencurigakan. Jika ada anomali, langkah

mitigasi seperti pembatasan akses atau pemblokiran IP secara otomatis akan diterapkan

6. Pelatihan Kesadaran Keamanan Informasi

- Kontrol Keamanan: A.7.2.2 Information Security Awareness, Education, and Training



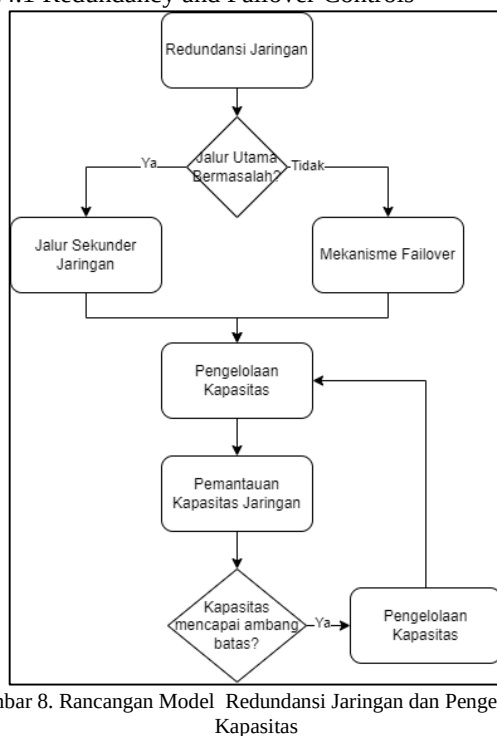
Gambar 7. Rancangan Model Perlindungan dari Serangan DDoS

Penerapan Model:

- **Pelatihan Berkala:** Semua pengguna SIMRS akan diwajibkan mengikuti pelatihan keamanan informasi secara berkala. Pelatihan ini mencakup pengenalan ancaman keamanan informasi, praktik terbaik dalam penggunaan aplikasi SIMRS, dan langkah-langkah mitigasi risiko yang harus diambil saat menggunakan aplikasi.
- **Simulasi Serangan:** Selain pelatihan teoretis, simulasi serangan (misalnya phishing atau social engineering) akan dilakukan untuk memastikan bahwa pengguna siap menghadapi ancaman nyata.
- **Evaluasi Kesadaran Keamanan:** Evaluasi terhadap tingkat kesadaran keamanan pengguna akan dilakukan melalui tes pengetahuan berkala dan penilaian terhadap respon mereka terhadap insiden keamanan informasi.

7. Redundansi Jaringan dan Pengelolaan Kapasitas

- Kontrol Keamanan: A.12.1.3 Capacity Management & A.12.4.1 Redundancy and Failover Controls



Gambar 8. Rancangan Model Redundansi Jaringan dan Pengelolaan Kapasitas

Penerapan Model:

- **Redundansi Jaringan:** Jaringan rumah sakit akan memiliki jalur komunikasi ganda (redundansi) untuk mencegah

terjadinya downtime saat jaringan utama mengalami kegagalan. Dengan mekanisme failover, layanan SIMRS akan otomatis dialihkan ke jalur sekunder jika jalur utama bermasalah.

- **Pengelolaan Kapasitas:** Sistem akan memantau kapasitas jaringan untuk memastikan ketersediaan bandwidth yang cukup bagi operasi SIMRS. Peningkatan kapasitas akan dilakukan secara otomatis jika jaringan mencapai ambang batas tertentu untuk memastikan performa jaringan optimal selama jam-jam sibuk.

IV. SIMPULAN

Menyoroti pentingnya penilaian risiko keamanan informasi pada Sistem Informasi Manajemen Rumah Sakit (SIMRS) di RS XYZ, dengan menggunakan kerangka kerja ISO/IEC 27005:2022. Penelitian ini menunjukkan bahwa SIMRS, sebagai sistem yang mengelola data sensitif seperti informasi pasien dan rekam medis, memiliki potensi risiko keamanan informasi yang tinggi jika tidak dikelola dengan baik. Ancaman yang teridentifikasi meliputi akses tidak sah, serangan DDoS, pencurian data, serta human error, yang dapat berdampak pada integritas, kerahasiaan, dan ketersediaan data rumah sakit. Pengelolaan risiko yang efektif sangat penting untuk memastikan kelangsungan operasional rumah sakit dan perlindungan terhadap data pasien sesuai dengan standar keamanan yang berlaku.

Implementasi kerangka ISO/IEC 27005:2022 memungkinkan rumah sakit untuk mengidentifikasi, menganalisis, dan mengelola risiko secara sistematis. Hasil penelitian ini menggarisbawahi bahwa ancaman dengan nilai risiko yang sangat tinggi, seperti pencurian data dan serangan DDoS, memerlukan tindakan mitigasi segera melalui kontrol keamanan seperti enkripsi, otentikasi dua faktor. Evaluasi risiko juga mengungkapkan bahwa risiko menengah dan tinggi dapat diterima dengan penerapan pengendalian tambahan seperti pelatihan keamanan bagi staf, peningkatan pengawasan, dan implementasi redundansi jaringan untuk menjaga stabilitas sistem. Dengan penilaian dan pengelolaan risiko yang tepat, RS XYZ dapat meningkatkan keamanan informasi secara signifikan, menjaga kepercayaan publik, dan meminimalkan dampak operasional akibat gangguan keamanan informasi. Penerapan kerangka kerja manajemen risiko keamanan informasi yang sesuai adalah langkah penting dalam menjaga integritas dan kelangsungan operasional rumah sakit di era digital.

REFERENSI

- [1] Agustinus, S., Nugroho, A., & Cahyono, A. D. (2017). Analisis Risiko Teknologi Informasi Menggunakan ISO 31000 pada Program HRMS. *Jurnal RESTI (Rekayasa Sistem dan Teknologi Informasi)*, 1(3), 250–258. <https://doi.org/10.29207/resti.v1i3.94>
- [2] Apriandari, W., & Sasongko, A. (2018). ANALISIS SISTEM MANAJEMEN KEAMANAN INFORMASI MENGGUNAKAN SNI ISO/IEC 27001:2013 PADA PEMERINTAHAN DAERAH KOTA SUKABUMI (STUDI KASUS: DI DISKOMINFO KOTA SUKABUMI). 8(1).

- [3] Bakri, M., & Irmayana, N. (2017). ANALISIS DAN PENERAPAN SISTEM MANAJEMEN KEAMANAN INFORMASI SIMHP BPKP MENGGUNAKAN STANDAR ISO 27001. *Jurnal Tekno Kompak*, 11(2), 41. <https://doi.org/10.33365/jtk.v11i2.162>
- [4] Budiarto, R. (2017). MANAJEMEN RISIKO KEAMANAN SISTEM INFORMASI MENGGUNAKAN METODE FMEA DAN ISO 27001 PADA ORGANISASI XYZ. 2(2).
- [5] Heryana, D., Setiawati, L., & Suhendar, B. (2020). SISTEM INFORMASI DAN POTENSI MANFAAT BIG DATA UNTUK PENDIDIKAN. *Gunahumas*, 2(2), 350–357. <https://doi.org/10.17509/ghm.v2i2.23023>
- [6] Hidayat, N., & Jatnika, I. (2022). PERANCANGAN SISTEM MANAJEMEN KEAMANAN INFORMASI DATA CENTER STANDART SNI ISO/IEC 27001:2013. 7(1).
- [7] Meilita Karendra Putri, & Hakim, A. R. (2021). Perancangan Manajemen Risiko Keamanan Informasi Layanan Jaringan MKP Berdasarkan Kerangka Kerja ISO/IEC 27005:2018 dan NIST SP 800-30 Revisi 1. *Info Kripto*, 15(3), 134–141. <https://doi.org/10.56706/ik.v15i3.34>
- [8] Octariza, N. F. (2019). Analisis sistem manajemen keamanan informasi menggunakan standar iso/iec 27001 dan iso/iec 27002 pada kantor pusat pt jasa mar (Bachelor's thesis, Fakultas Sains dan Teknologi Universitas Islam Negeri Syarif Hidayatullah Jakarta).
- [9] Oktavia, A. B., Fauzi, R., & Nugraha, R. A. (2020). PERANCANGAN MANAJEMEN KEAMANAN INFORMASI MENGGUNAKAN KONTROL ISO 27001 PADA PT. XYZ.
- [10] Papuangan, M., Hizbullah, I., & Doe, A. (2020). PERANCANGAN SISTEM INFORMASI AKADEMIK SEKOLAH BERBASIS WEB PADA SMP NEGERI 1 PULAU MOROTAI.
- [11] Putri, T. S., Mutiah, N., & Prawira, D. (2022). ANALISIS MANAJEMEN RISIKO KEAMANAN INFORMASI MENGGUNAKAN NIST CYBERSECURITY FRAMEWORK DAN ISO/IEC 27001:2013. 10(02).
- [12] Riana, E. (2022). Analisis Maturity Level Dan PDCA Dalam Penerapan Proses Audit SMKI (Information Security Management System) Menggunakan ISO 27001:2013 Pada PT Indonesia Game. 7(1).
- [13] Sarno & Iffano. (2009). *Sistem Manajemen Keamanan Informasi*. Surabaya: ITS Press.
- [14] Sallaby, A. F., & Kanedi, I. (2020). Perancangan Sistem Informasi Jadwal Dokter Menggunakan Framework Codeigniter. *JURNAL MEDIA INFOTAMA*, 16(1). <https://doi.org/10.37676/jmi.v16i1.1121>
- [15] Whitman, Michael E dan Mattord Herbert J. "Priciples of Information Security. USA: Course Technology". 2011.
- [16] Yustanti, W., Qoiriah, A., Bisma, R., & Prihanto, A. (2019). Strategi Identifikasi Resiko Keamanan Informasi Dengan Kerangka Kerja ISO 27005:2018. *Journal of Information Engineering and Educational Technology*, 3(2), 51–56. <https://doi.org/10.26740/jieet.v3n2.p51-56>
- [17] Zahra, Medina Nurul, et al. "Manajemen risiko sistem informasi rumah sakit (Studi kasus: rumah sakit EMC Tangerang)." *Prosiding Seminar Nasional Mahasiswa Bidang Ilmu Komputer dan Aplikasinya*. Vol. 2. No. 1. 2021.